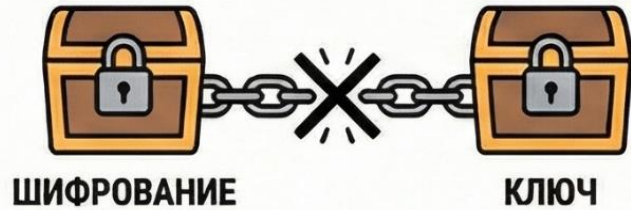


SSH и Диффи — Хеллман: Магия безопасной связи

Как создать защищенный канал в открытом интернете без передачи паролей.

1. ПРОБЛЕМА «КУРИЦЫ И ЯЙЦА» РЕШЕНА



Раньше для шифрования нужен был ключ, а для его безопасной передачи — уже зашифрованный канал.

2. ОДНОСТОРОННИЕ ФУНКЦИИ — ОСНОВА ЗАЩИТЫ



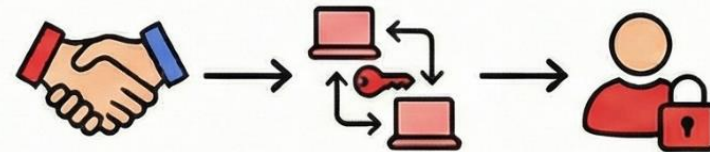
Почти невозможно вычислить обратно (например, дискретное логарифмирование).

3. ПРОТОКОЛ ДИФФИ — ХЕЛЛМАНА



Стороны обмениваются открытыми данными, на основе которых каждая вычисляет идентичный секретный ключ, не передавая его по сети.

4. SSH: ТРИ ЭТАПА ЗАЩИТЫ СОЕДИНЕНИЯ



1. ТСП-СВЯЗЬ (ПОДКЛЮЧЕНИЕ)

2. СОГЛАСОВАНИЕ КЛЮЧА ПО DH

3. АУТЕНТИФИКАЦИЯ ПОЛЬЗОВАТЕЛЯ

Сначала устанавливается связь, затем согласуется ключ, и проводится проверка подлинности.

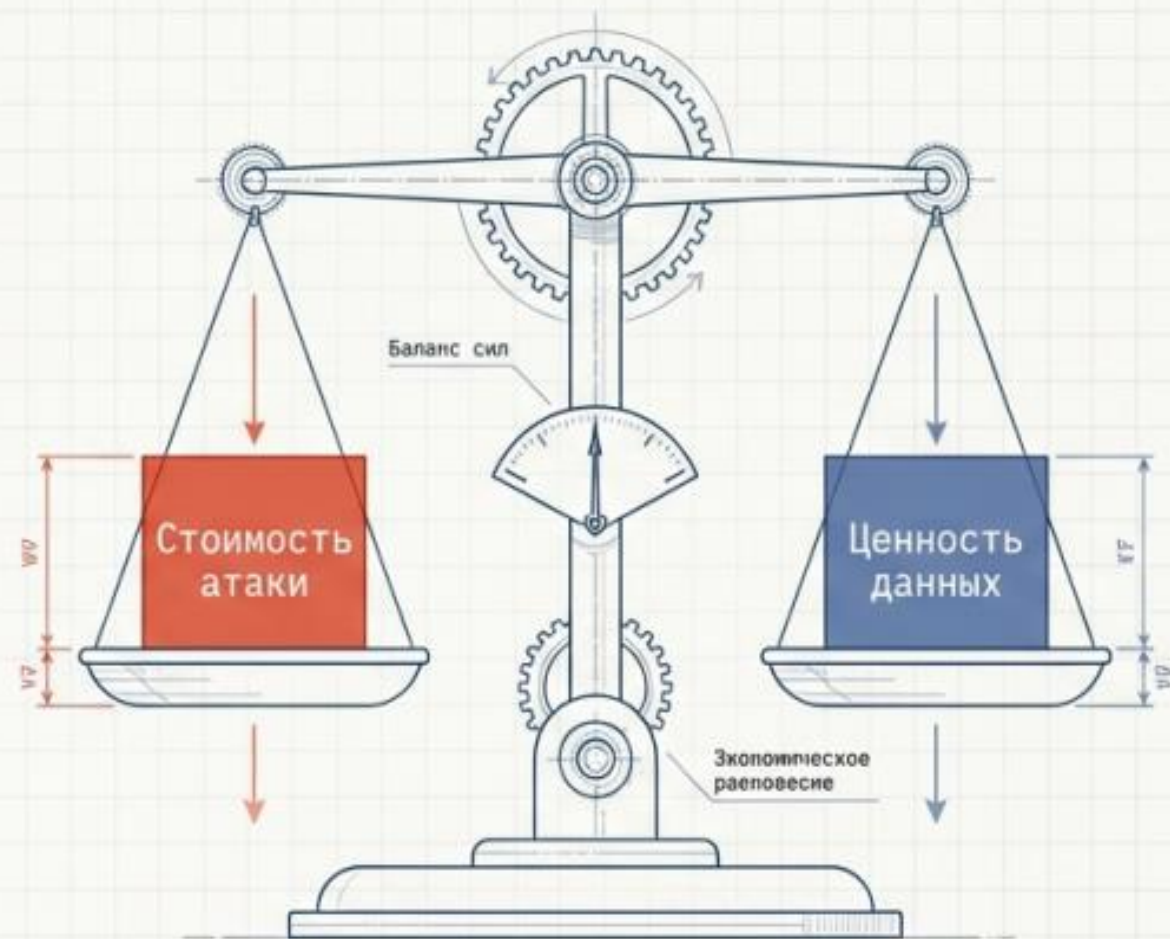
5. ДОКАЗАТЕЛЬСТВО С НУЛЕВЫМ РАЗГЛАШЕНИЕМ



Метод позволяет доказать знание секрета (пароля), не раскрывая сам секрет проверяющей стороне.



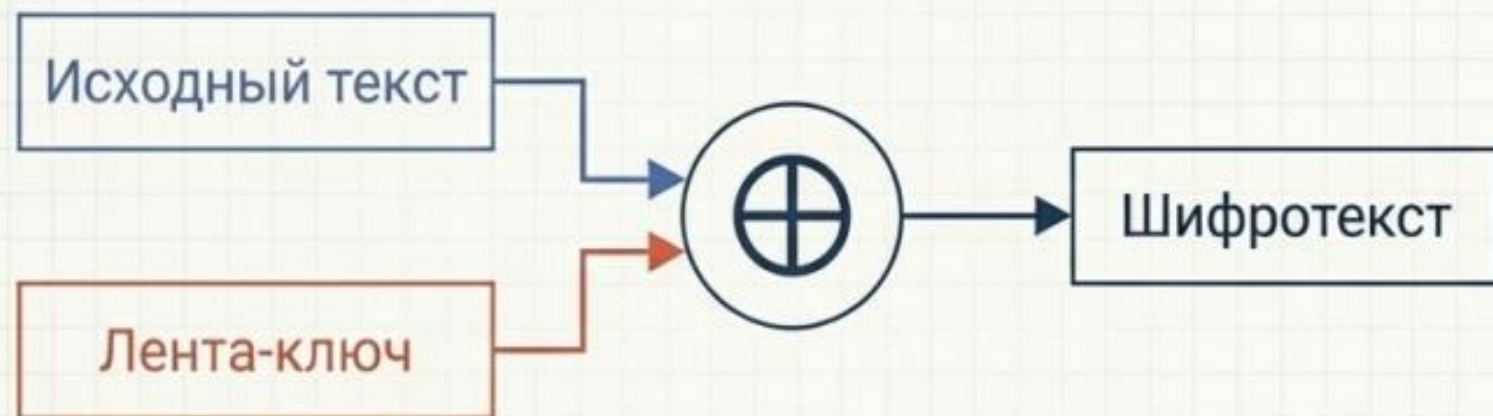
Стороны обмениваются открытыми данными, на основе которых каждая вычисляет идентичный секретный ключ, не передавая его по сети.



Заметки лектора:

Золотое правило оценки: затраты на шифрование не должны превышать стоимость самой информации. Точно так же, если затраты противника на взлом выше ценности данных – система практически безопасна.

Абсолютная стойкость: Схема Вернама (1917)



Условия абсолютной
стойкости:

- ✓ Ключ равен длине сообщения
- ✓ Ключ абсолютно случаен
- ✓ Ключ используется строго один раз

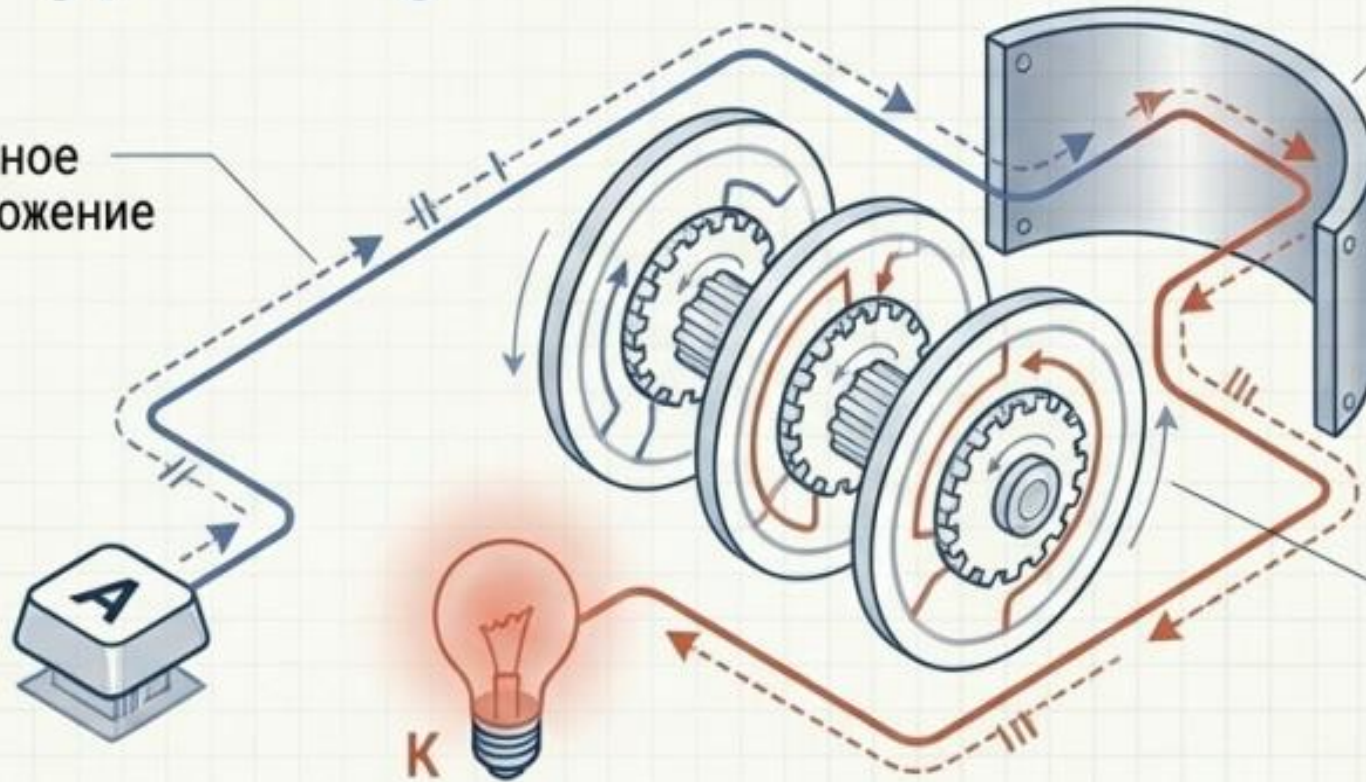
Шифротекст = Сообщение + Лента-ключ

Заметки лектора:

Клод Шеннон доказал, что схема Вернама абсолютно стойкая. Если соблюдены три условия, шифр невозможно взломать, так как шифротекст не содержит статистической информации об исходном сообщении.

Эпоха электромеханики: Архитектура «Enigma»

Ключ: Ежедневное начальное положение барабанов.



Рефлектор: Замыкает цепь и меняет буквы буквами парами. Делает шифрование обратимым.

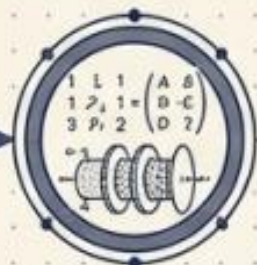
Барабаны (Одометр): Сдвигаются при каждом нажатии. Схема постоянно меняется.

Заметки лектора:

Принцип одометра: электрическая схема меняется при каждом нажатии клавиши. Рефлектор позволял использовать одну машину для шифрования и расшифровки, но его предсказуемость стала главной уязвимостью.

Битва за шифры: Математика против Механики

Теория: Математический анализ



1932: Варшава

Марнан Ршеевский применяет теорию групп и перестановок для воссоздания структуры «Энигмы» без самой машины.



1939: Блетчли-Парк

Алан Тьюринг создает программируемый компьютер Colossus для скоростного перебора ключей и распределенных вычислений.

Практика: Физический захват



1942: Фронт

Захват самой машины и ежедневной книги кодов, что позволило читать сообщения в реальном времени.

Фундаментальная слабость

Безопасность системы опиралась не на математическую стойкость, а на физическое владение книгой ключей. Захват книги = компрометация всей сети.



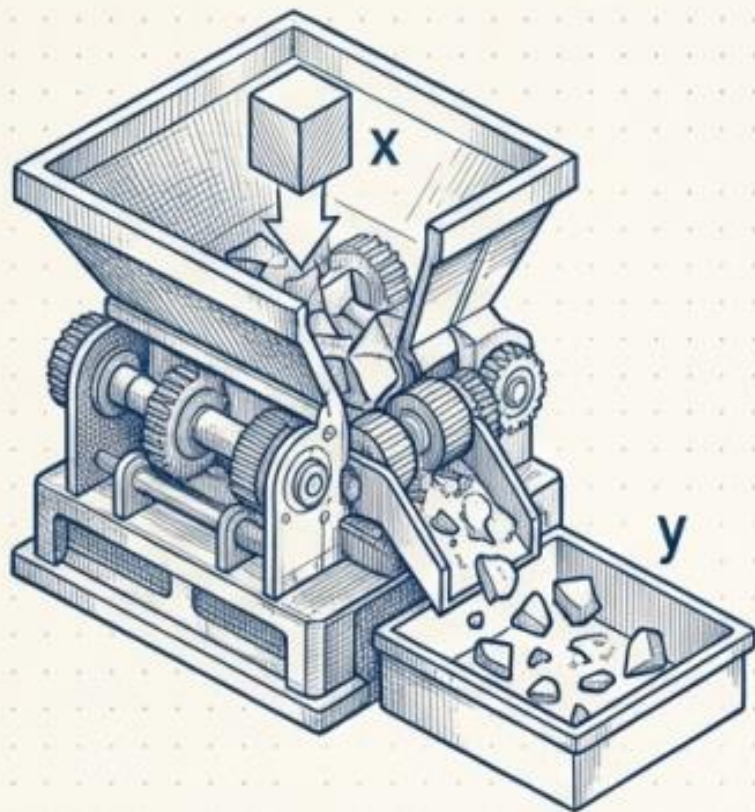


Симметричные алгоритмы исключительно быстры и надежны, но Алисе и Бобу все еще нужно безопасно встретиться лично, чтобы передать секретный ключ.



Анатомия функций: Как скрыть секрет на виду

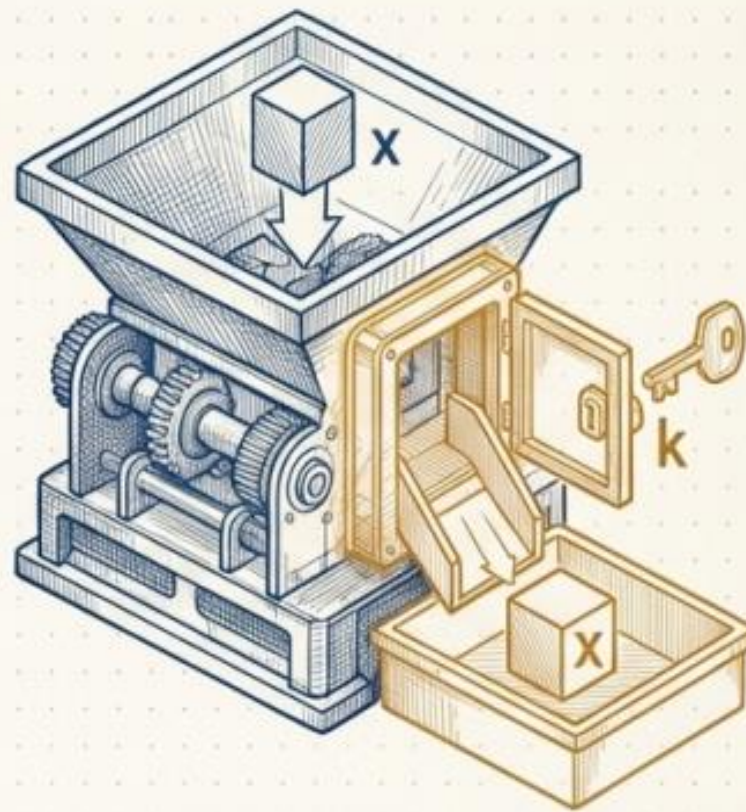
Односторонняя функция $f(x)$



Свойство: Вычислить $y = f(x)$ легко алгоритмически. Найти обратную функцию (восстановить x из y) практически невозможно.

Проблема: Законный получатель тоже не сможет расшифровать сообщение. Данные заперты навсегда.

Функция с секретом (Trapdoor)



Свойство: Для всех это обычная односторонняя функция. Но при знании секретного свойства k можно построить эффективную обратную функцию.

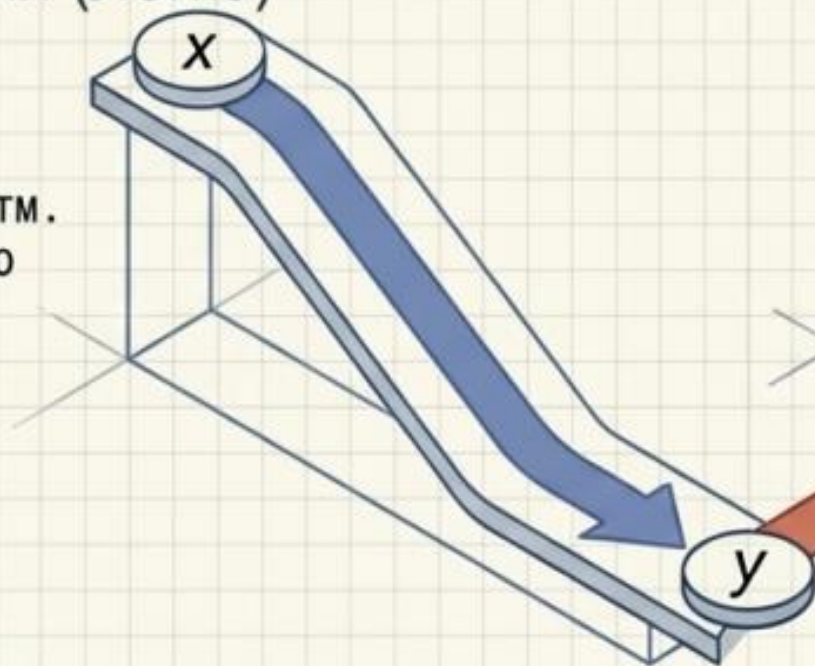
Решение: Математическая основа асимметричной криптографии. Решает проблему безопасного обмена ключами.

Математическая формализация: Односторонние функции

Прямая функция (Легко)

$$y = f(x)$$

Существует эффективный алгоритм. Зная функцию, легко зашифровать текст.



Обратная функция (Трудно)

$$x = f^{-1}(y)$$

Эффективного алгоритма не существует. Зная шифр, невозможно восстановить текст.



Заметки лектора:

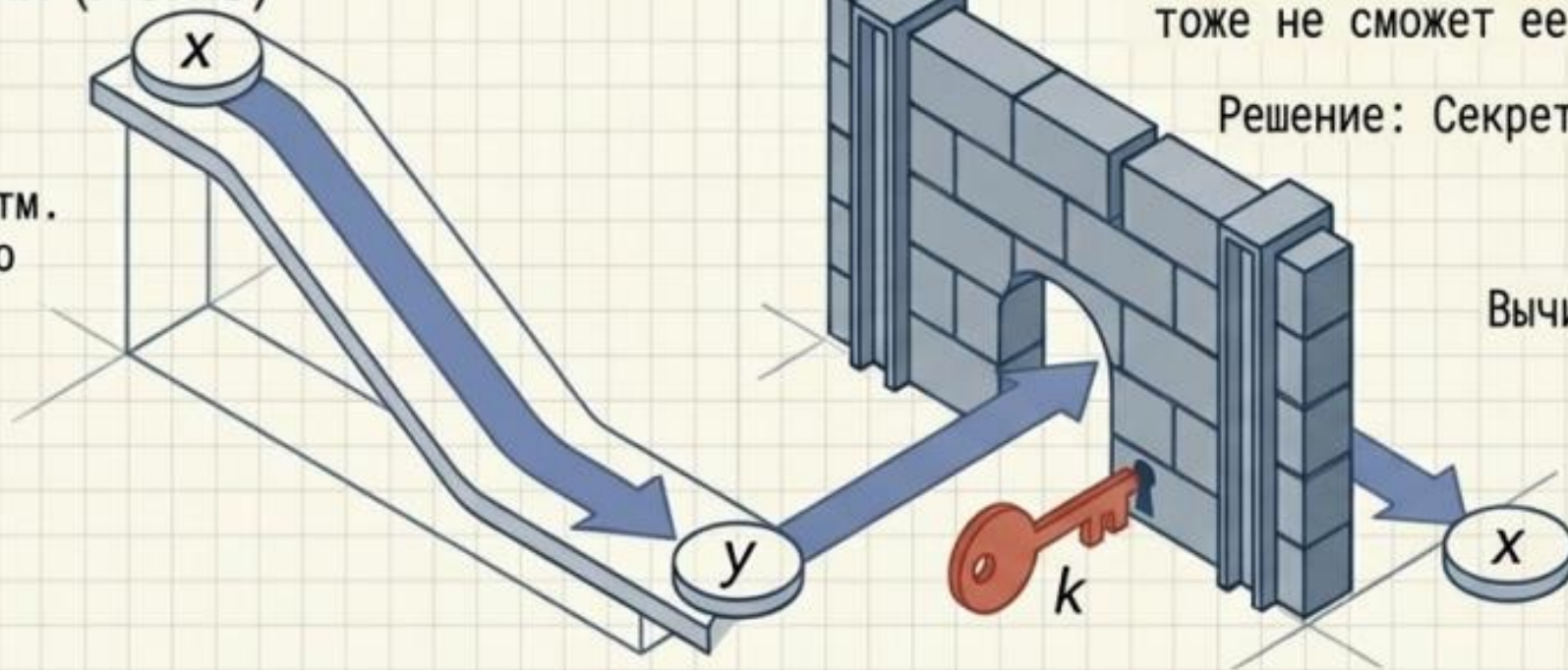
Вся безопасность строится на математическом парадоксе: функция должна быть вычислительно простой в одну сторону, но астрономически сложной в обратную. Эту стену невозможно пробить.

Односторонние функции с секретом (Trapdoor functions)

Прямая функция (Легко)

$$y = f(x)$$

Существует эффективный алгоритм. Зная функцию, легко зашифровать текст.



Проблема: Обычная односторонняя функция бесполезна – законный получатель тоже не сможет ее расшифровать.

Решение: Секретное свойство k (Черный ход)

Без знания k :
Вычисление $f^{-1}(y)$ невозможно.

Со знанием k :
 $f_k^{-1}(y) = x$
(мгновенная расшифровка).

Заметки лектора:

Нам нужна функция с секретом (Trapdoor). Секрет k – это скрытая дверь в математической стене. Тот, кто создал функцию, оставляет ключ себе, позволяя всем остальным безопасно передавать данные.

Примитивные протоколы: Жеребьевка без доверия

Сценарий:

Как двум не доверяющим друг другу абонентам бросить жребий по телефону, чтобы никто не смог сжульничать?



Алиса (А)

Боб (В)

Шаг 1:

Алиса прячет шарик

Алиса выбирает случайное x , вычисляет $f(x)$ (закрывает шарик в коробку) и отправляет $f(x)$ Бобу.



Шаг 2:

Боб угадывает

Боб угадывает четность x (цвет шарика) и называет свою догадку Алисе.

Шаг 3:

Алиса открывает коробку

Алиса сообщает результат и отправляет Бобу исходный x , подтверждая свой выбор.



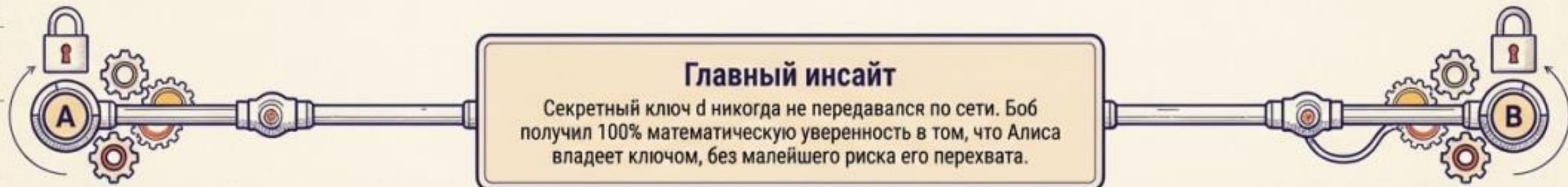
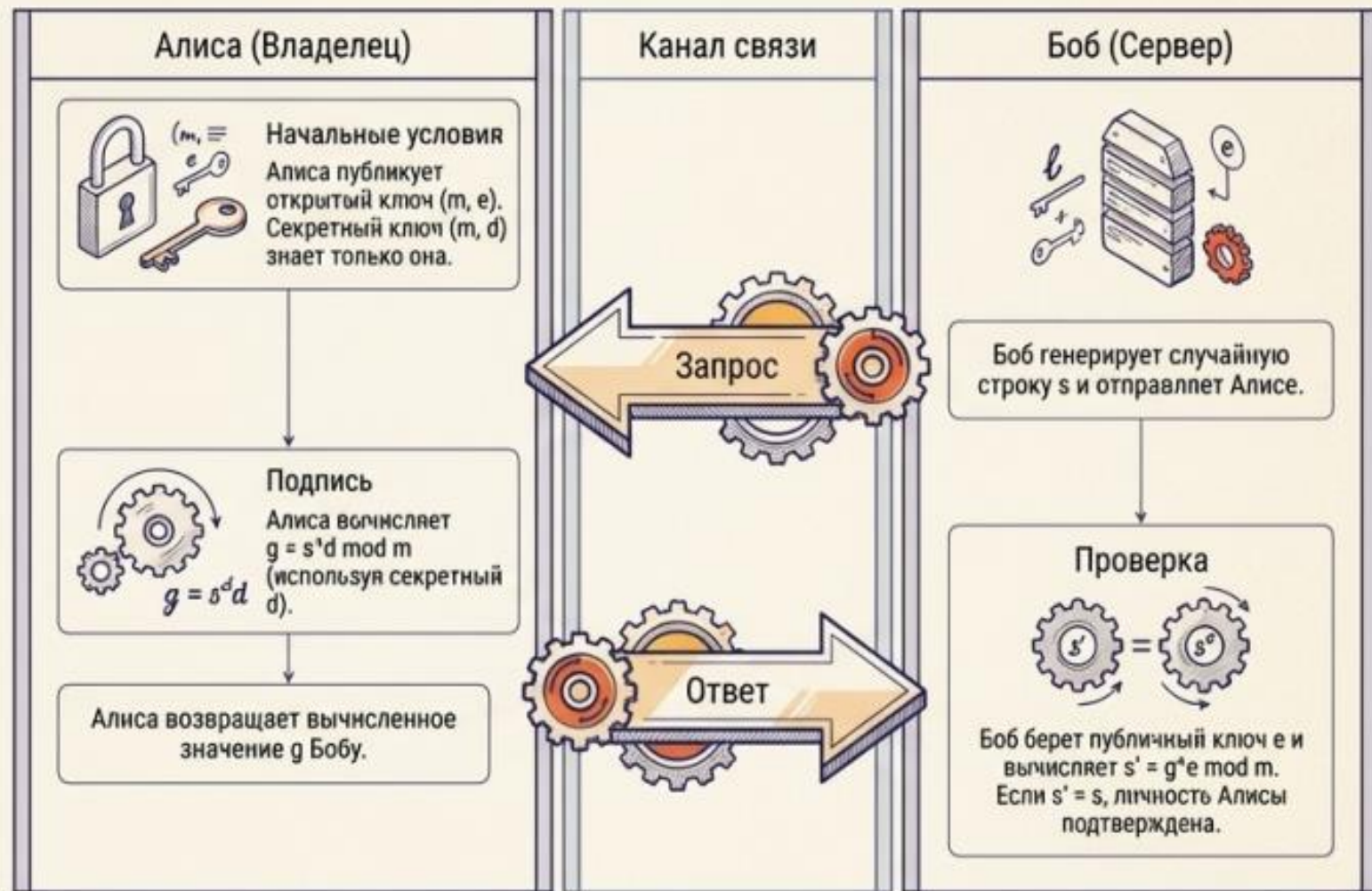
Шаг 4: Проверка Боба

Боб сам вычисляет $f(x)$ и сравнивает с данными из Шага 1. Свойства функции исключают подмену x : угадать четность по $f(x)$ невозможно, а изменить четность, сохранив значение $f(x)$, математически недостижимо.



Протокол аутентификации (RSA)

Разграничение доступа требует проверки полномочий без раскрытия самого пароля. База данных проверяет идентичность пользователя, обмениваясь только вычисляемыми данными.



Высшая форма доверия: Zero-Knowledge Proof (ZKP)

В 1985 году Шафи Голдвассер и Сильвио Микали изменили природу математического доказательства. ZKP — это метод доказать знание информации, не раскрывая о ней ни единого бита.



1. Целостность (Completeness)

Если утверждение истинно, то честный доказывающий всегда сможет убедить честного проверяющего в знании информации.



2. Точность (Soundness)

Если утверждение ложно, ни один нечестный участник математически не сможет в одностороннем порядке обмануть проверяющего.

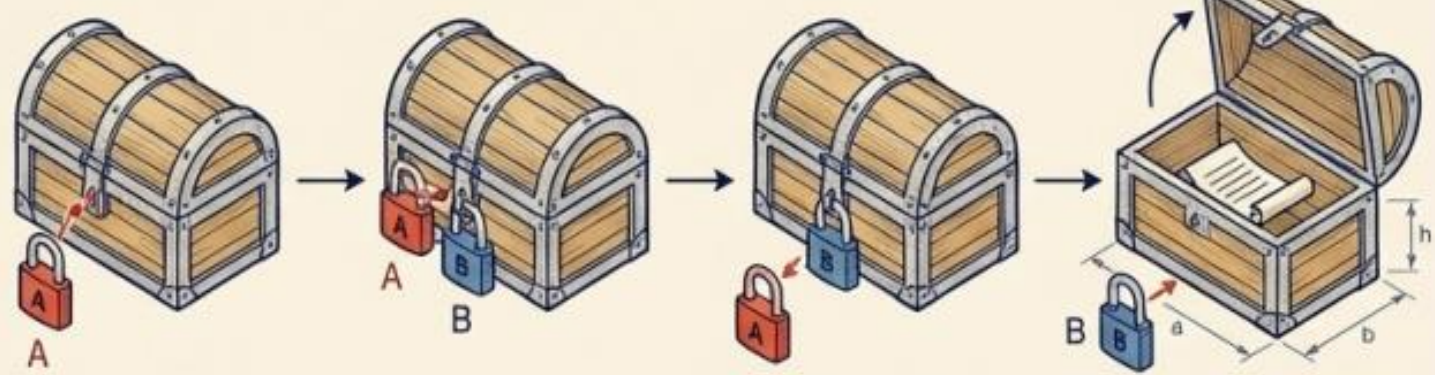
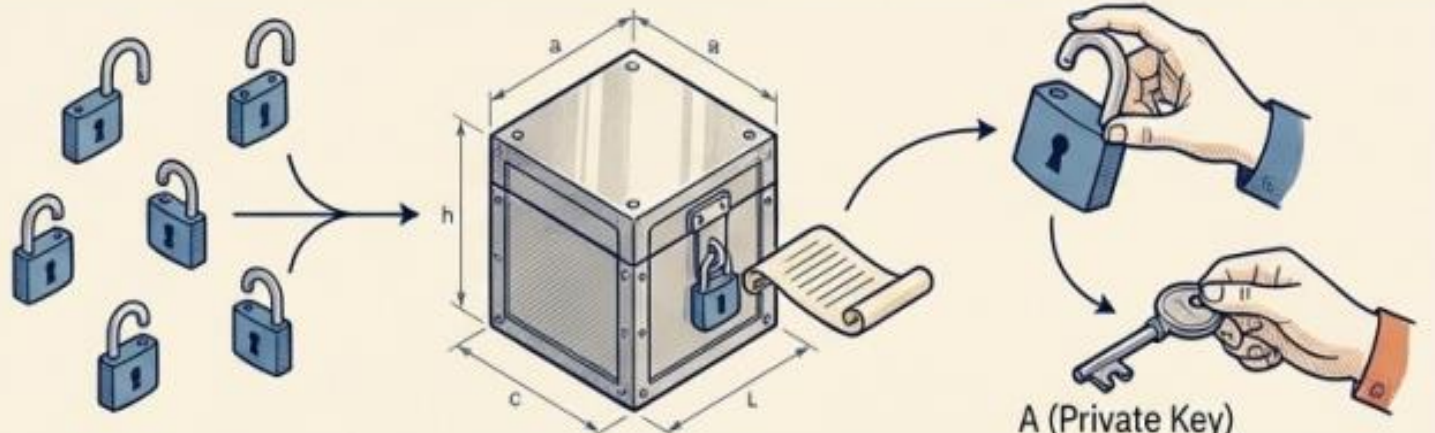


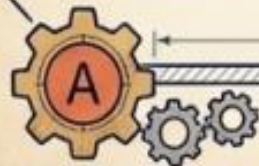
3. Нулевое разглашение (Zero-Knowledge)

Проверяющий не узнает из процесса доказательства абсолютно ничего, кроме самого факта, что утверждение истинно.



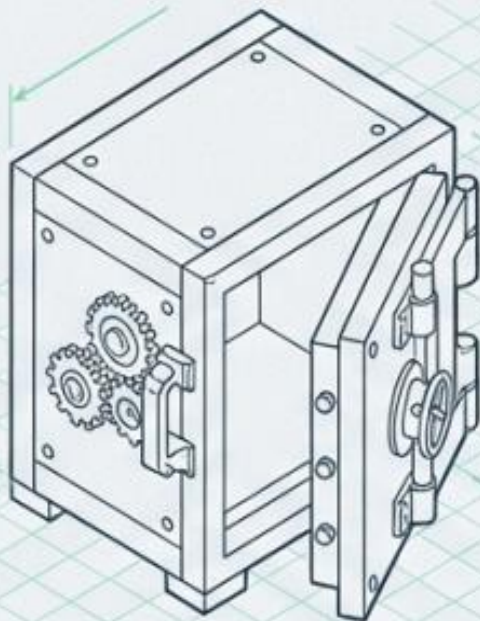
Физические модели асимметричного доверия

1	Модель «Сундук с двумя замками» (Протокол Шамира)		Механика: Сообщение передается без обмена ключами. Письмо кладется внутрь сундука, и ни одну секунду сундук не находится в пути без защиты. Замки навешиваются и снимаются последовательно.
2	Модель «Навесного замка» (Принцип открытого ключа RSA)		Механика: Открытый ключ (незащелкнутый замок) доступен всем. Закрытый ключ (физический ключ от замка) есть только у Алисы. Боб защелкивает замок, после чего открыть ящик может исключительно Алиса.

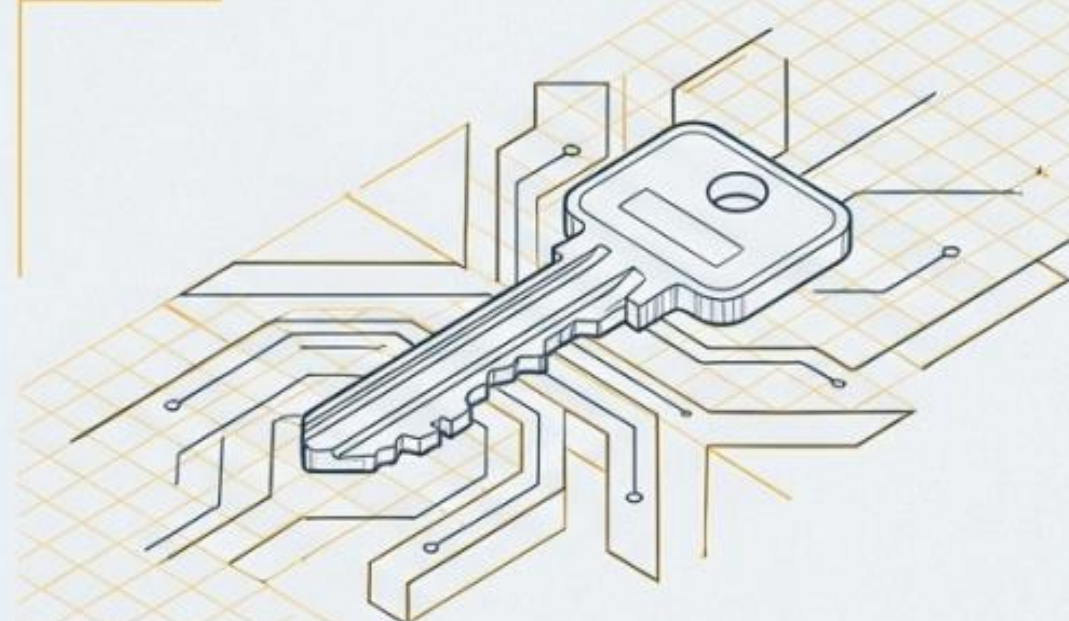


Парадокс распределения ключей до 1976 года

До публикации работы Диффи и Хеллмана криптография сталкивалась с фундаментальной «проблемой курицы и яйца»:



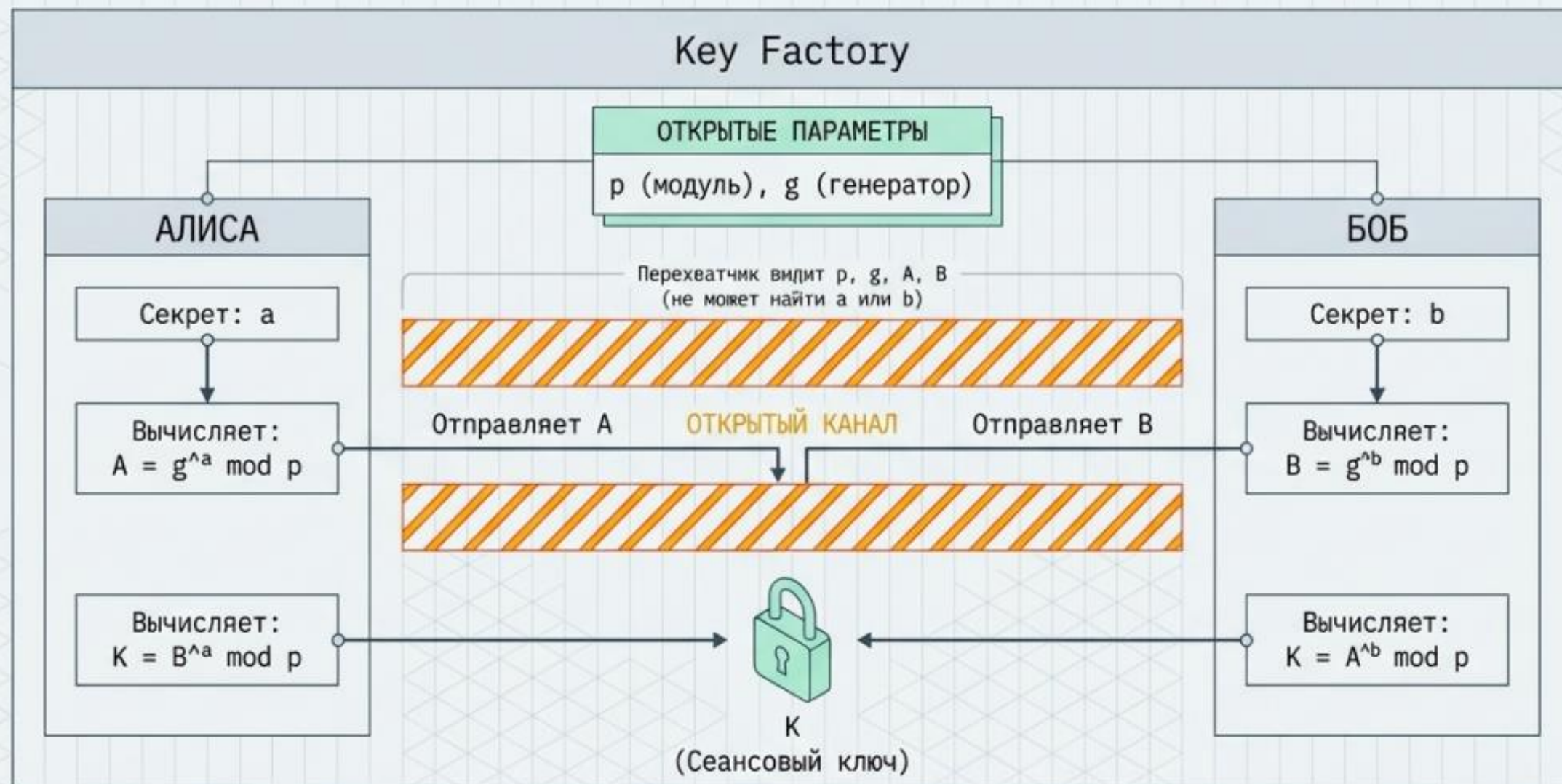
Чтобы передавать данные в зашифрованном виде, сторонам нужен общий секретный ключ.



Чтобы безопасно передать этот ключ по открытой сети, канал уже должен быть зашифрован.

Исторический тупик: Требовалась личная встреча для передачи ключей. Отправка ключа по открытой сети означала его немедленную компрометацию.

Механика генерации общего секрета



Математическая магия равенства: $(g^b)^a = (g^a)^b = K \mod p$. Обе стороны независимо получают одинаковое число K , ни разу не передав его по сети.

Фундаментальная уязвимость: отсутствие аутентификации

Классический протокол DH уязвим для атаки **Man-in-the-Middle** (MITM).



Механизм атаки: Злоумышленник перехватывает компоненты, подменяет их своими и устанавливает два отдельных соединения. Обе стороны фактически обмениваются ключами с перехватчиком.

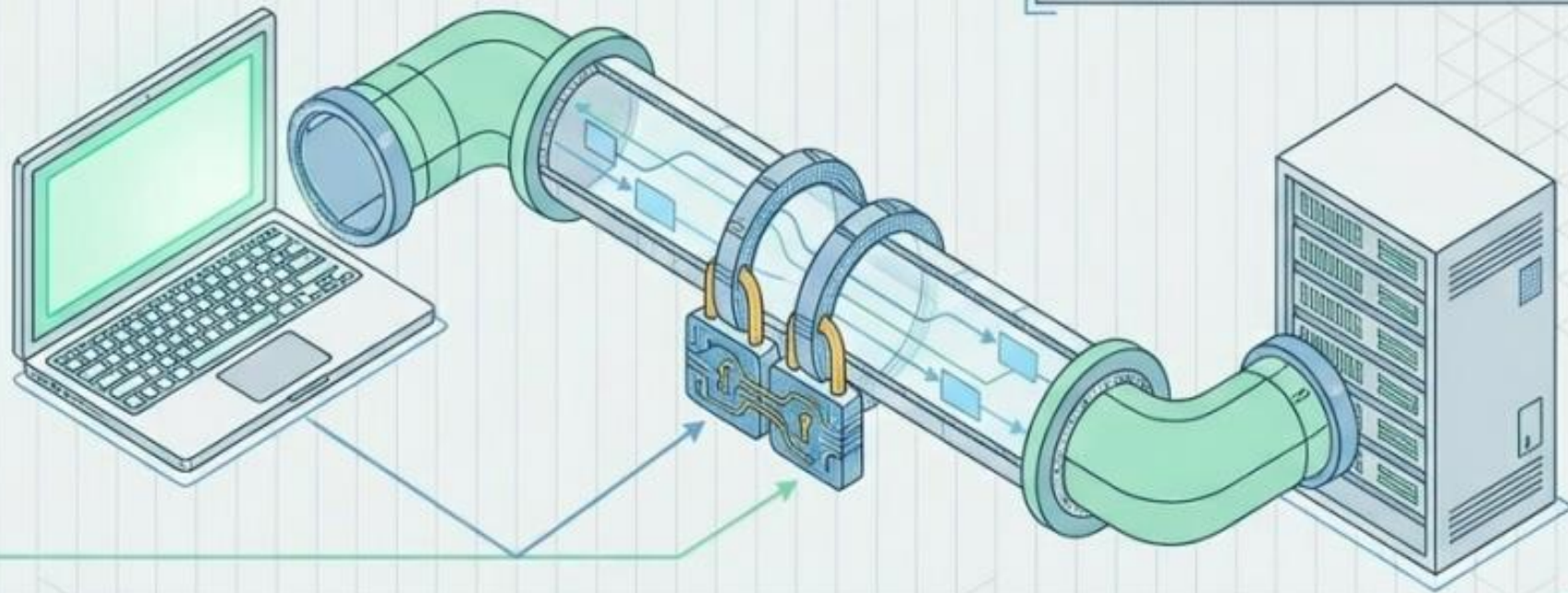
Вывод: Чистый DH позволяет безопасно договориться о ключе, но не позволяет проверить, с кем именно вы договариваетесь. Требуется проверка личности.

Secure Shell (SSH): Прикладная защита от перехвата



1995: Хельсинкский технологический университет

После успешной атаки со сниффингом (перехватом паролей) студент Тату Юлёнен разработал протокол SSH.



Диффи-Хеллман (DH): Создает общий секретный ключ для защиты канала связи от прослушивания.



Электронная подпись (RSA): Обеспечивает строгую аутентификацию сервера и клиента, устраняя угрозу Man-in-the-Middle.

Смена парадигмы: Устаревшие протоколы против SSH

	Ранние протоколы (Telnet, FTP)	Современный стандарт (SSH, SFTP) 
Формат данных	Обычный текст (Plain text) 	Симметричное AES-шифрование сеанса 
Уязвимость	Критически подвержены сниффингу; пароли открыты 	Устойчивы к перехвату; данные выглядят как белый шум 
Аутентификация	Базовая защита паролем (без криптографии) 	Пары открытого/закрытого ключей (RSA) 
Целостность	Данные могут быть незаметно изменены в пути 	Криптографическая гарантия неизменности данных 

Архитектура соединения: Три этапа сеанса SSH

1. Обмен ключами



Клиент и сервер безопасно согласовывают общий сеансовый ключ с помощью криптопротокола Диффи-Хеллмана.

2. Проверка ключа



Сервер отправляет зашифрованный вызов. Клиент доказывает свою личность, успешно расшифровывая его своим закрытым ключом.

3. Передача данных



Устанавливается симметричное шифрование (AES-256). Единый ключ защищает все выполняемые команды и файлы.

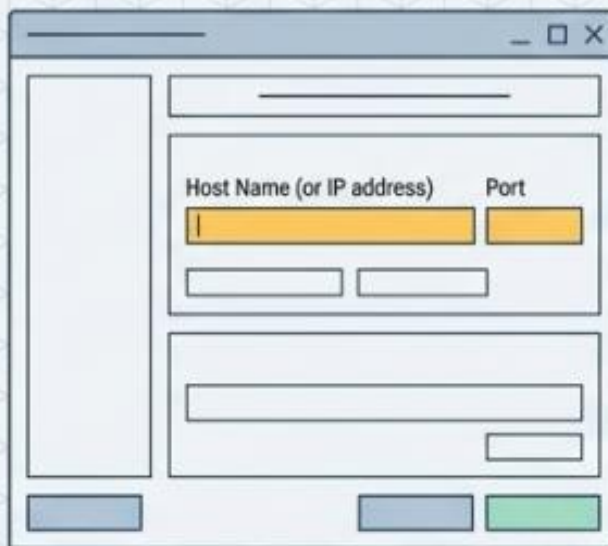
Практическая реализация: Подключение к серверу (Windows)

SSH работает по классической модели клиент-сервер.



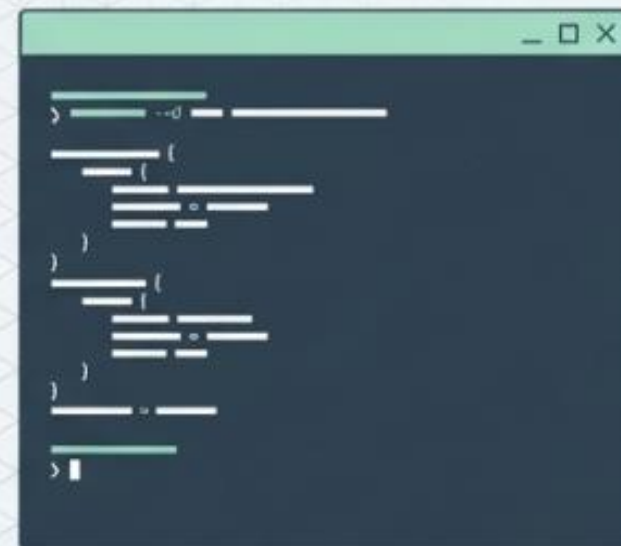
Шаг 1. Клиент

Установка кроссплатформенного приложения (например, PuTTY / Cмder)



Шаг 2. Инициализация

Ввод IP-адреса удаленного хоста и порта подключения



Шаг 3. Взаимодействие

Безопасное удаленное управление — перемещение файлов, создание каталогов через зашифрованный терминал

Укрепление периметра: Лучшие практики безопасности SSH

Базовой установки SSH недостаточно для полной защиты. Рекомендуется внедрить следующие архитектурные изменения:



Изменение порта по умолчанию

Перенос SSH со стандартного порта TCP 22 на нестандартный (через `iptables`) для защиты от автоматизированных сканеров и DDoS-атак.



Аутентификация по ключам

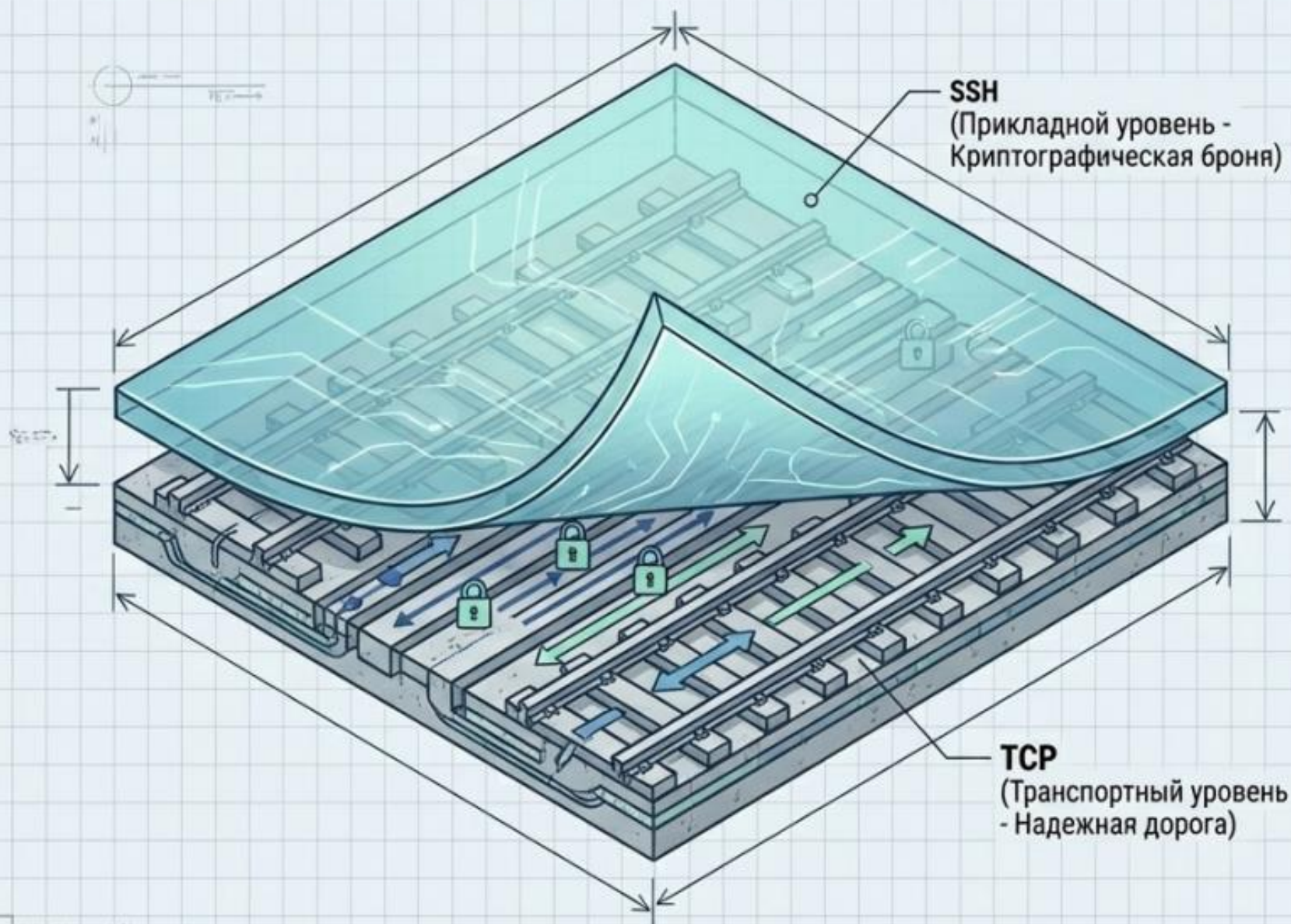
Использование генерации пар ключей вместо паролей. Открытый ключ размещается на сервере с помощью утилиты `ssh-copy-id`.



Блокировка root-входа

Отключение прямого входа в систему для суперпользователя. Вход осуществляется под обычной учетной записью с последующим повышением привилегий.

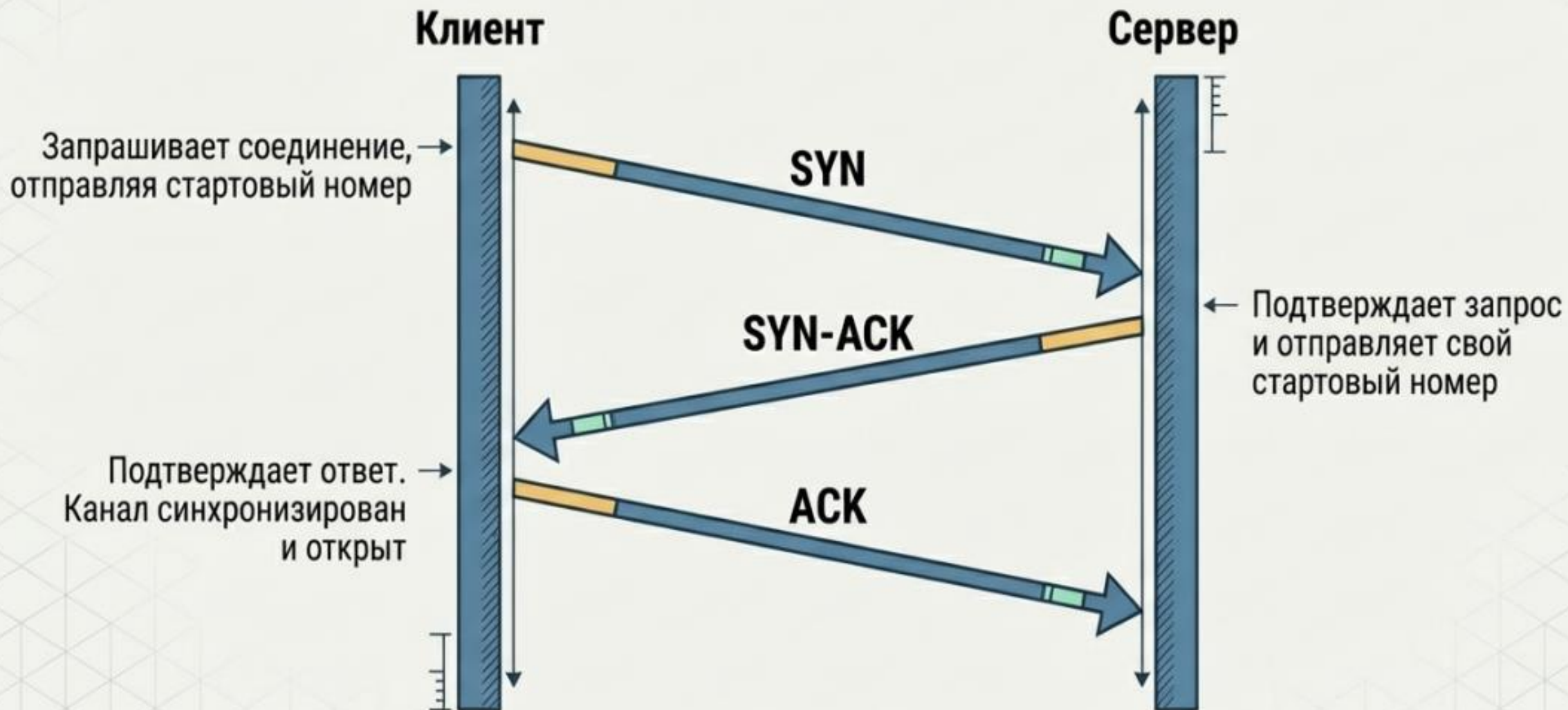
Фундаментальный носитель: Роль протокола TCP



SSH обеспечивает броню, но перемещение данных через интернет требует надежной магистрали. Работая поверх IP, протокол TCP гарантирует доставку данных в правильном порядке и без потерь. TCP спроектирован для надежной и последовательной передачи данных, компенсируя нестабильность физических сетей.

Установка канала: Трехстороннее рукопожатие

До начала передачи зашифрованных данных SSH, протокол TCP должен установить гарантированный канал связи:

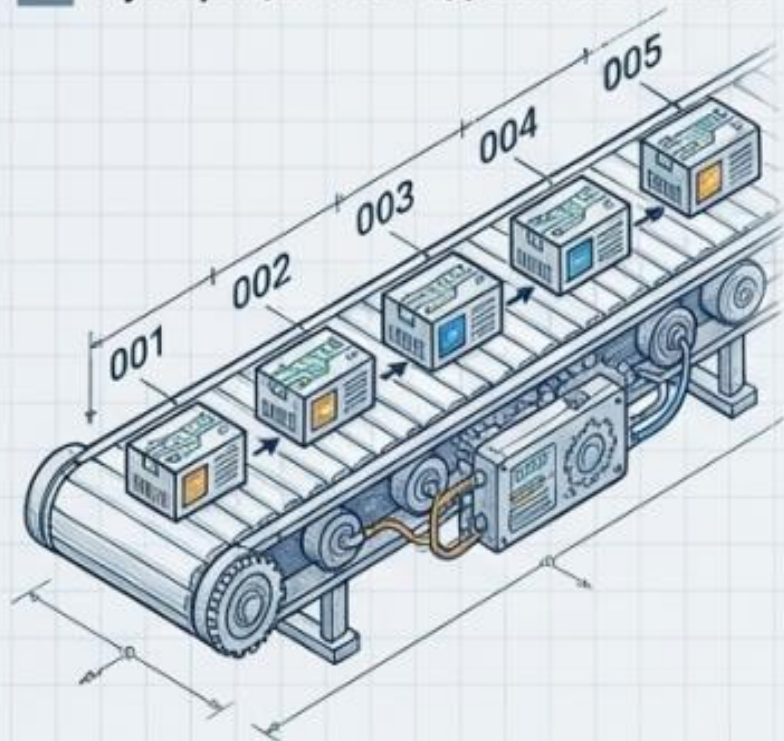


Механизмы надежности: Поддержание целостности потока

Во время сеанса SSH генерируются огромные объемы данных. TCP использует три механизма для управления этим потоком:

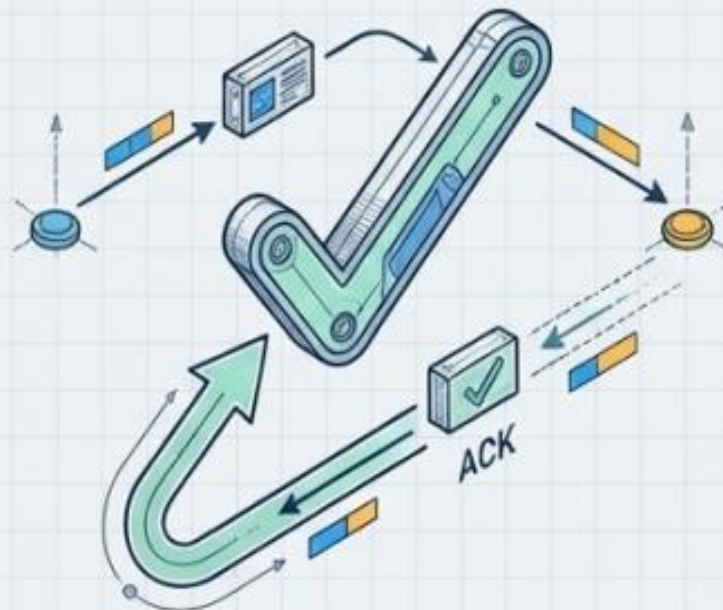
Dashboard

1 Нумерация последовательностей



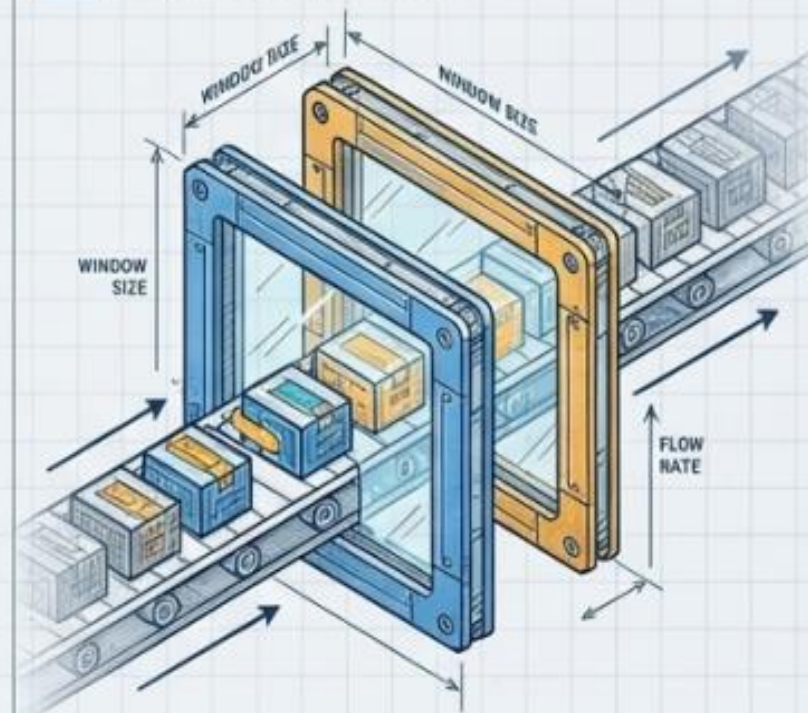
Каждому байту присваивается уникальный номер для строгого соблюдения порядка команд.

2 Квитирование (ACK)



Отправитель дублирует потерянные сегменты, если не получает подтверждение (ACK) от получателя.

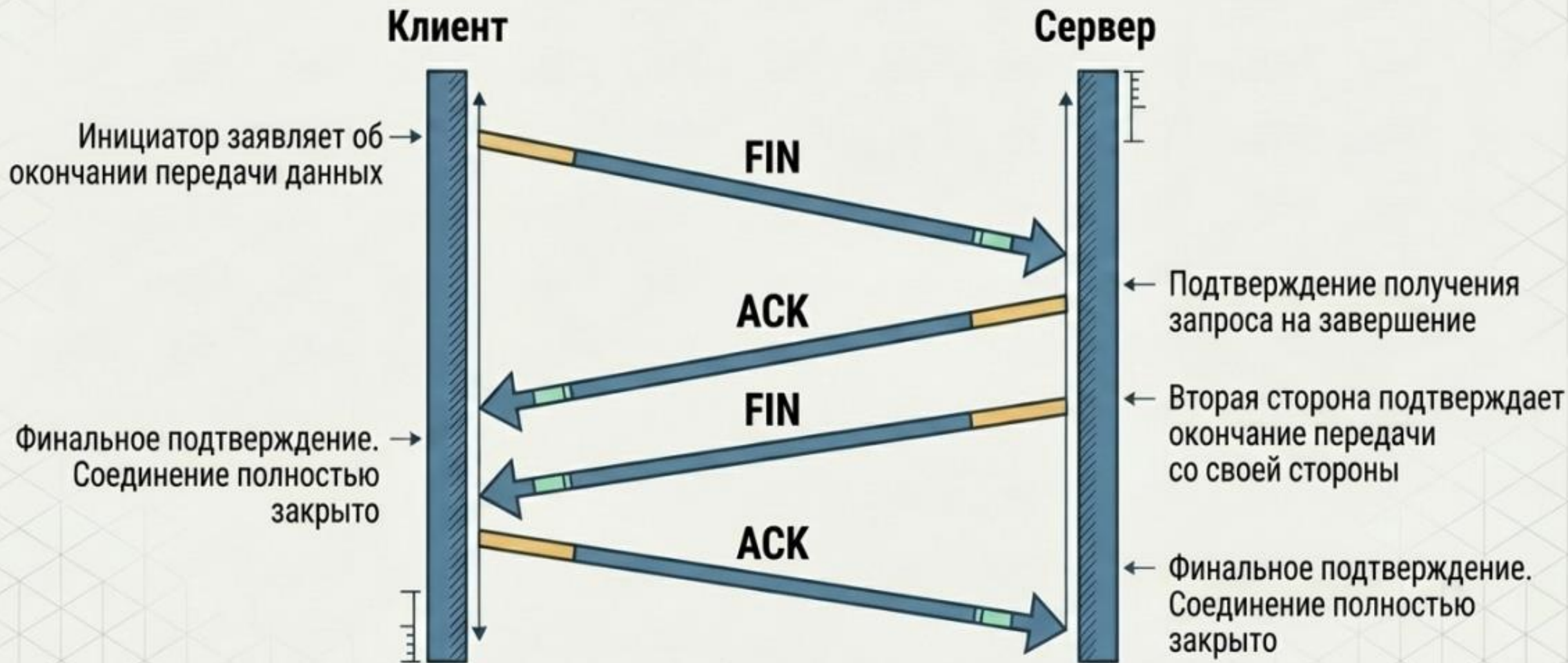
3 Скользящее окно



Динамический контроль перегрузки, регулирующий скорость и объем отправляемых данных.

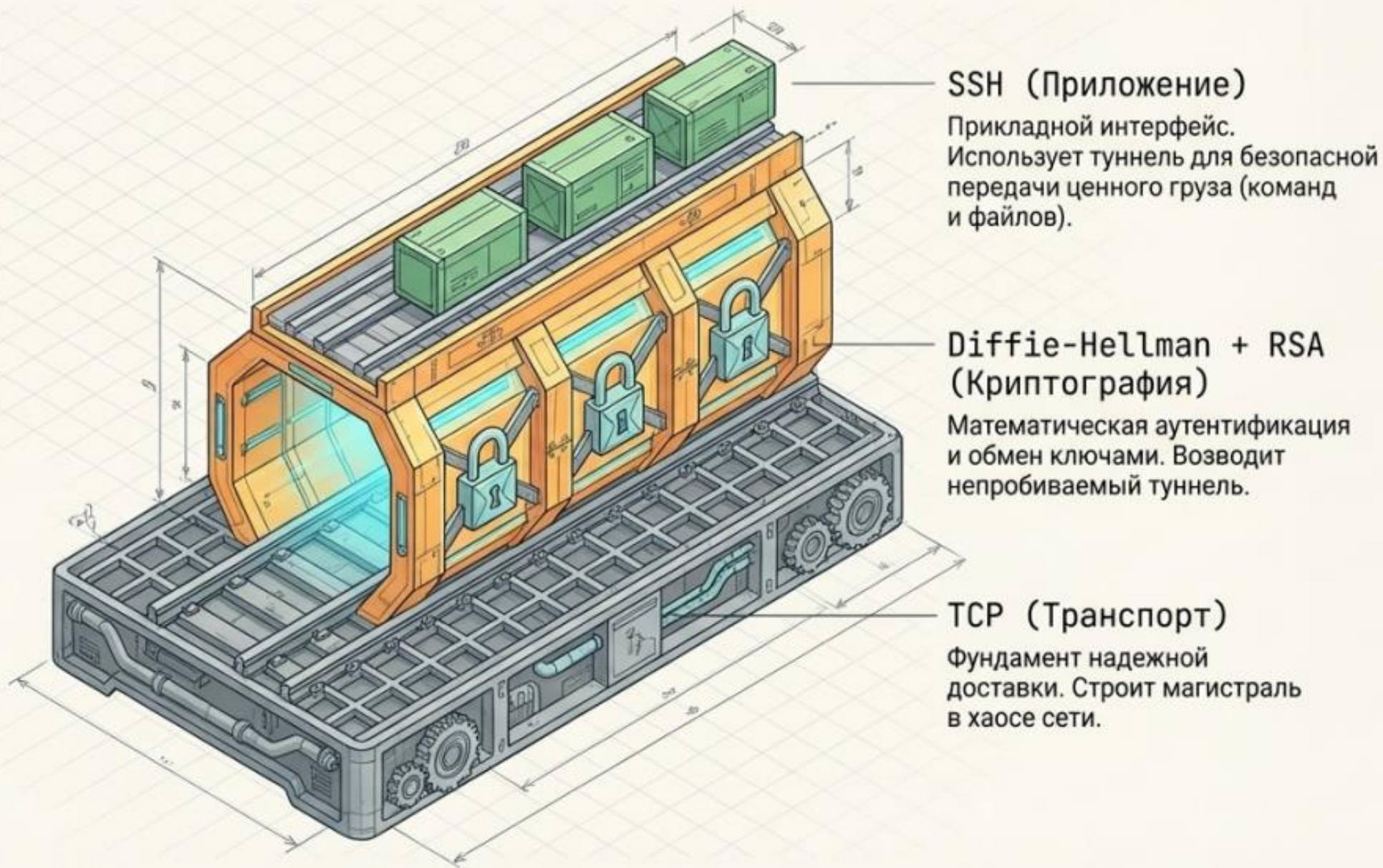
Корректное завершение: Четырехэтапный разрыв соединения

TCP гарантирует упорядоченное закрытие сеанса без потери финальных пакетов данных. Соединение закрывается только после обоюдного согласия.



Синтез: Полный стек защищенных коммуникаций

Безопасность современного интернета — это синергия узкоспециализированных протоколов.



ОСНОВЫ КРИПТОГРАФИИ

Лекция № 1. Введение в криптографию

Основные понятия, терминология ГОСТ и цели защиты информации

➔ Загрузить

Введение в криптографию: основные понятия, терминология ГОСТ и цели защиты информации

